PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Politique de filtrage réseau (ANSSI)

03-420 ANSSI - Définition d'une politique de filtrage réseau d'un pare-feu — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'évaluation des règles s'effectue de manière séquentielle du haut vers le bas avec une seule règle par flux.
2. La politique doit être organisée en 6 sections distinctes incluant l'administration, la protection du pare-feu, les flux métiers et une interdiction finale.
3. La réalisation de revues régulières est obligatoire et n'est jamais dispensée par des mécanismes de contrôle techniques ou organisationnels.

Contexte et application du modèle

Notion	À retenir
Justification	La **complexification des architectures**, l'ajout de **fonctionnalités**, l'**historique lourd** et la **rotation des équipes** dégradent les politiques.
Conditions	Évaluation **séquentielle** (haut en bas), **une seule règle** par flux, et possibilité de définir les flux **vers/depuis le pare-feu**.

Organisation de la politique de filtrage

Notion	À retenir
Flux vers/depuis FW	Section 1 : accès **administration** et **supervision** (sources/services précis). Section 2 : flux **émis par** le FW (**journaux**, **alertes**, **sauvegarde**) avec destinations/services précis.
Protection du FW	Section 3 : **une seule règle** en `drop` sans réponse vers **toutes les interfaces**, avec **journalisation systématique**.
Flux métiers	Section 4 : **l'essentiel de la politique**, règles d'autorisation selon une logique (entité ou service) avec sources, destinations et services précis.
Antiparasites et fin	Section 5 (facultative) : **antiparasites** sans journalisation (ex: **broadcast**). Section 6 : **interdiction finale** unique et **journalisée** pour garantir le **modèle positif**.

Mise en forme de la politique

Notion	À retenir
Objets et nommage	Types : **machine**, **réseau**, **plage réseau**, **service** ou **groupe**. Convention selon orientation **fonctionnelle** (`srv_dns-interne`) ou **technique** (`srv_appollo`).
Coloration et règles	Coloration par **niveau de confiance** ou **rôle fonctionnel**. Nom de règle : indique le **sens**. Commentaire : **descriptif**, **date**, **n° ticket**, **intervenant**.
Séparateurs de règles	Employés pour faire apparaître les **6 sections** et les **regroupements de flux métiers** (avec convention de nommage si champ texte disponible).

Bonnes pratiques et cycle de vie

Notion	À retenir
Désactivation flux implicites	**Désactiver** les flux (administration, VPN, DNS, ICMP...) et les **définir manuellement** pour réduire la surface d'attaque et connaître les règles.
Séquence de démarrage	Entre l'**allumage** et l'application de la politique, le trafic peut passer **sans contrôle** (pire cas) : se documenter et **tester ce comportement avant toute maintenance avec redémarrage**.
Documentation et maintenance	**Documenter** et diffuser les consignes, **tester** la politique, et effectuer une **revue bi-annuelle ou annuelle** minimum pour corriger les écarts et obsolescences.

Pièges et confusions

- ⚠ Confondre l'action interdire avec une réponse d'erreur (elle correspond à une suppression silencieuse sans réponse).
- ⚠ Penser que l'interdiction implicite de la solution technique suffit (une règle d'interdiction finale explicite et journalisée doit être ajoutée).
- ⚠ Croire que les mécanismes de contrôle de la politique dispensent des revues régulières.
- ⚠ Oublier que les flux implicites doivent être désactivés et définis manuellement pour réduire la surface d'attaque.

Sigles et définitions

Stateful	Filtrage réseau tenant compte de l'état des connexions préalablement établies.
Modèle de sécurité positif	Consiste à interdire par défaut tout ce qui n'est pas explicitement autorisé.
Règle antiparasite	Règle facultative interdisant certains flux non autorisés sans en conserver la trace.
Flux implicite	Flux ouvert automatiquement par la solution technique pour l'administration ou le fonctionnement.
Séparateur de règles	Fonctionnalité technique permettant de scinder visuellement la politique de filtrage.

Auto-test

1. Quelle est la méthode d'évaluation des règles ?
2. Combien de règles doit-on appliquer par flux ?
3. Quelle est la fréquence minimum pour une revue de la politique ?
4. Que doit-on faire des flux implicites ?
5. Quel est l'objectif d'une règle antiparasite ?

Réponses : **1.** Séquentielle (haut en bas). · **2.** Une seule. · **3.** Bi-annuelle ou annuelle. · **4.** Les désactiver et les définir manuellement. · **5.** Interdire certains flux sans conserver leur trace pour garder des journaux exploitables.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.